

Seguridad en IA

Jaime A Riascos-Salas

MLOps II – 2026

UBA

Contenido extraído de:

https://www.cloudskillsboost.google/paths/1283/course_templates/1147/documents/530207?locale=es

¿Por qué debería importarte la seguridad de la IA?

¿Por qué debería importarte la seguridad de la IA?

El Dilema de la IA: Oportunidad vs. Riesgo

- **Visión Optimista vs Visión Cautelosa**

El Conflicto Central:

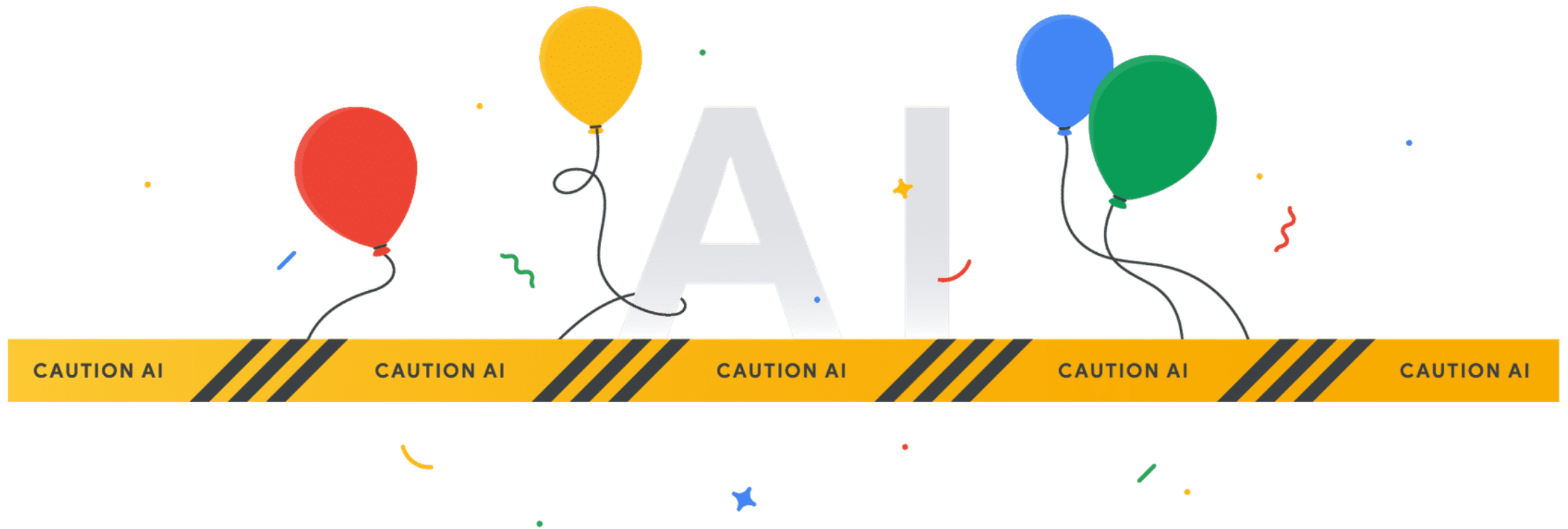
- Nos enfrentamos a un dilema clásico: la promesa de la innovación frente al miedo a lo desconocido.

Pregunta clave: ¿Cómo innovar con IA sin exponer a la empresa u organización a riesgos innecesarios?

La revolución de la Inteligencia Artificial (IA) es innegable.

- **IA: ¿Adoptar o ser Cautelosos?**
- **Presencia Dominante:** La IA está en todas partes, generando una pregunta clave: ¿es realmente segura para mi empresa?
- **El Impulso para Adoptar:**
 - **Promesa:** Optimizar operaciones, mejorar la eficiencia y abrir nuevas oportunidades.
 - **Demanda Interna:** Los empleados desean usarla para innovar en su trabajo.
 - **Mandato Estratégico:** El directorio la considera esencial para la competitividad.
- **Las Preocupaciones Válidas:**
 - **Seguridad de Datos:** ¿Podemos confiarle información sensible de clientes y de la empresa?
 - **Gobernanza:** ¿Existen las protecciones y los lineamientos éticos adecuados?
 - **Riesgo Reputacional:** ¿Podría la IA filtrar datos confidenciales o tomar decisiones perjudiciales?

La revolución de la Inteligencia Artificial (IA) es innegable.



Principales Riesgos de la IA en la Empresa

Seguridad y Robo de Datos:

- ¿Existe el riesgo de que la IA filtre o haga un uso inadecuado de datos internos o de clientes?

Propiedad Intelectual y Derechos de Autor:

- ¿Podrían los empleados usar contenido generado por IA que infrinja derechos de autor, exponiendo a la empresa a riesgos legales?

Pérdida Financiera:

- **Fraude y Errores:** ¿Pueden los fallos o el uso malicioso de la IA causar pérdidas directas o interrupciones operativas?
- **Costos Ocultos:** ¿Se han considerado todos los costos de implementación y mantenimiento (infraestructura, talento, imprevistos)?

Cumplimiento y Ética (Riesgos Legales y de Reputación):

- ¿Podrían los modelos de IA generar resultados discriminatorios o violar normativas de privacidad como el GDPR?

¿Cómo interactuar con la IA?



Crear modelos de IA

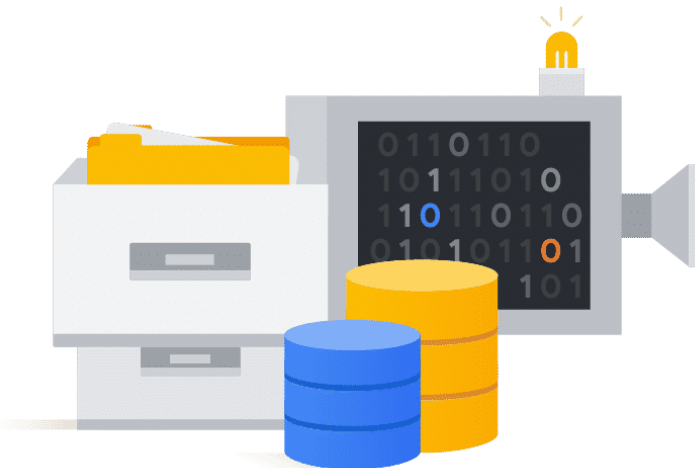
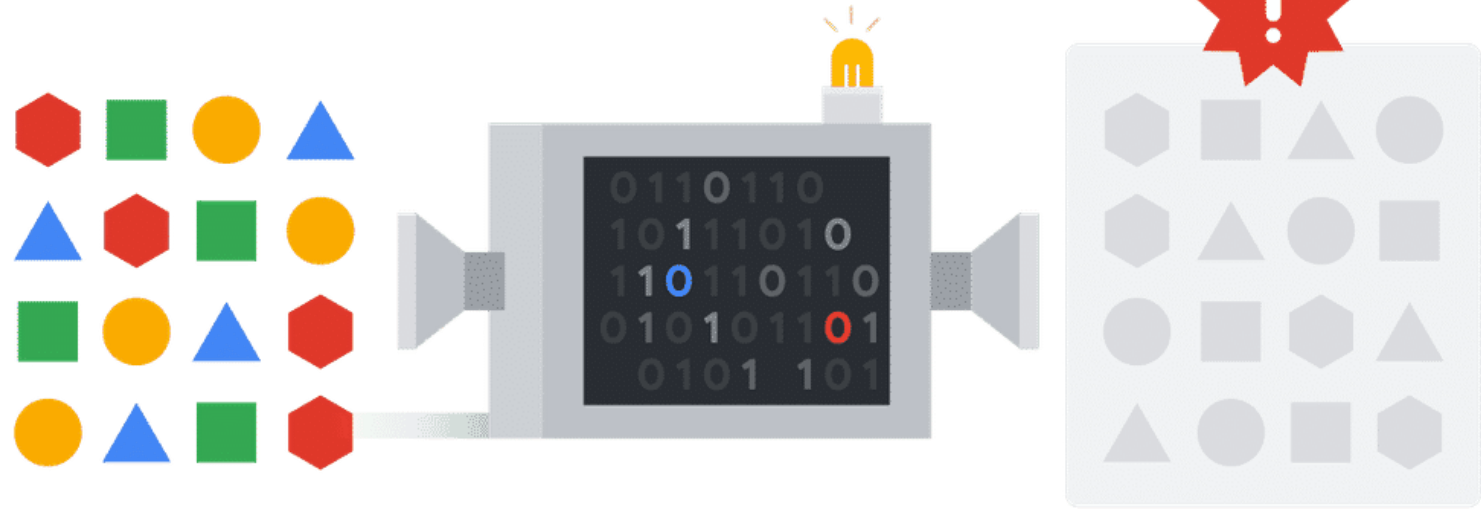
Crear aplicaciones o APIs

Usar aplicaciones potenciadas por
IA

¿De dónde provienen los datos? ¿A dónde se dirigen?

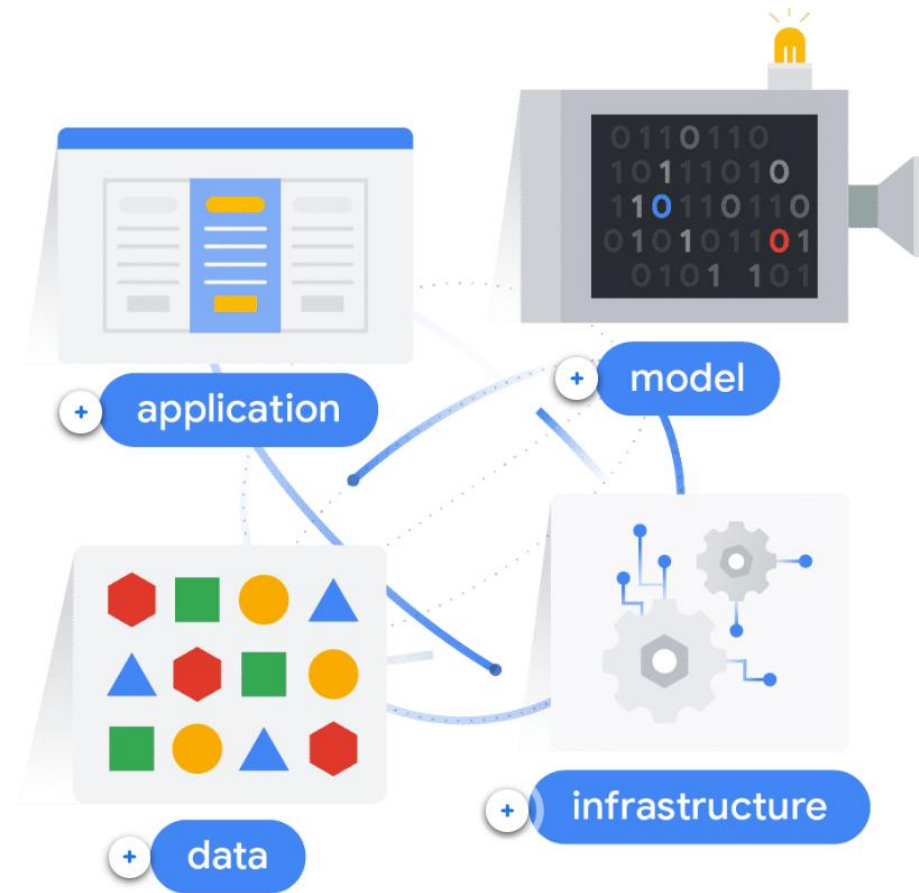
- **Resultados Directos:** Datos de mala calidad = resultados de mala calidad.
- **Riesgo de Fugas:** Si los datos contienen información sensible, el modelo podría revelarla accidentalmente.
- **Contenido Inapropiado:** El modelo puede replicar lenguaje obsceno o enlaces no seguros presentes en su entrenamiento.

- **Analogía Clave:** Proporcionar datos a una IA es como rellenar un formulario web; siempre estás compartiendo información.
- **Acción Requerida:** Antes de usar cualquier aplicación (de IA o no), evalúa qué datos compartes y cómo se podrían utilizar.



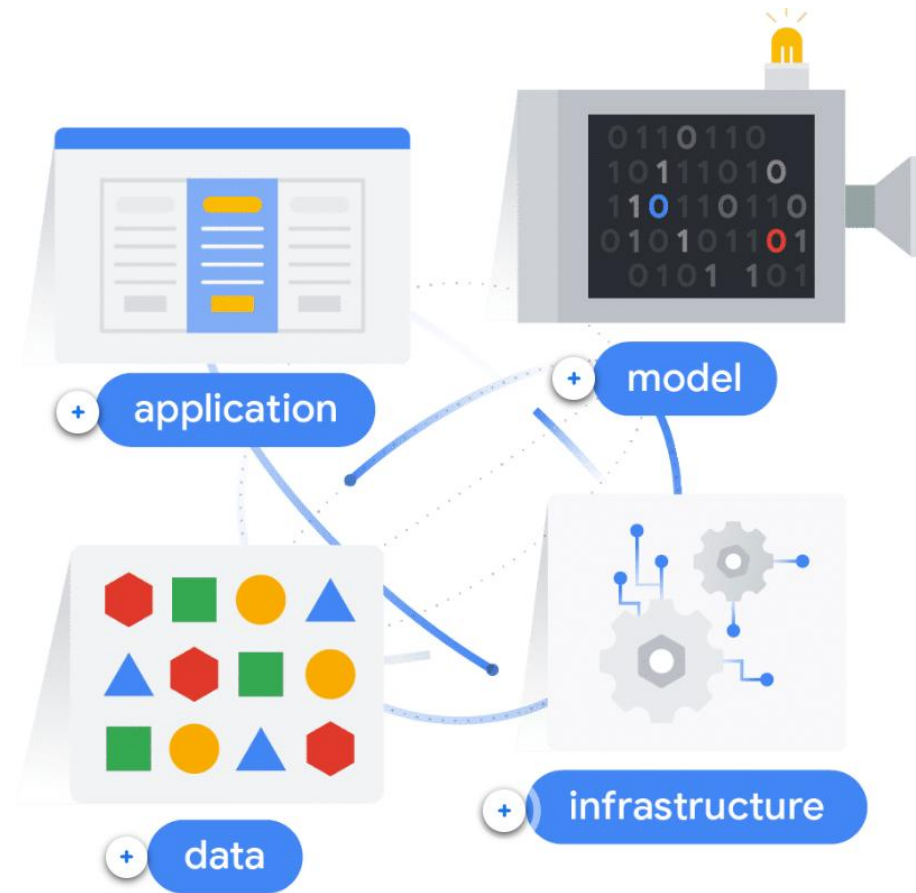
- **Consumidores:** Es común que utilicen tus interacciones para mejorar sus servicios o re-entrenar el modelo.

Garantizar seguridad = Conocer el sistema IA



Garantizar seguridad = Conocer el sistema IA

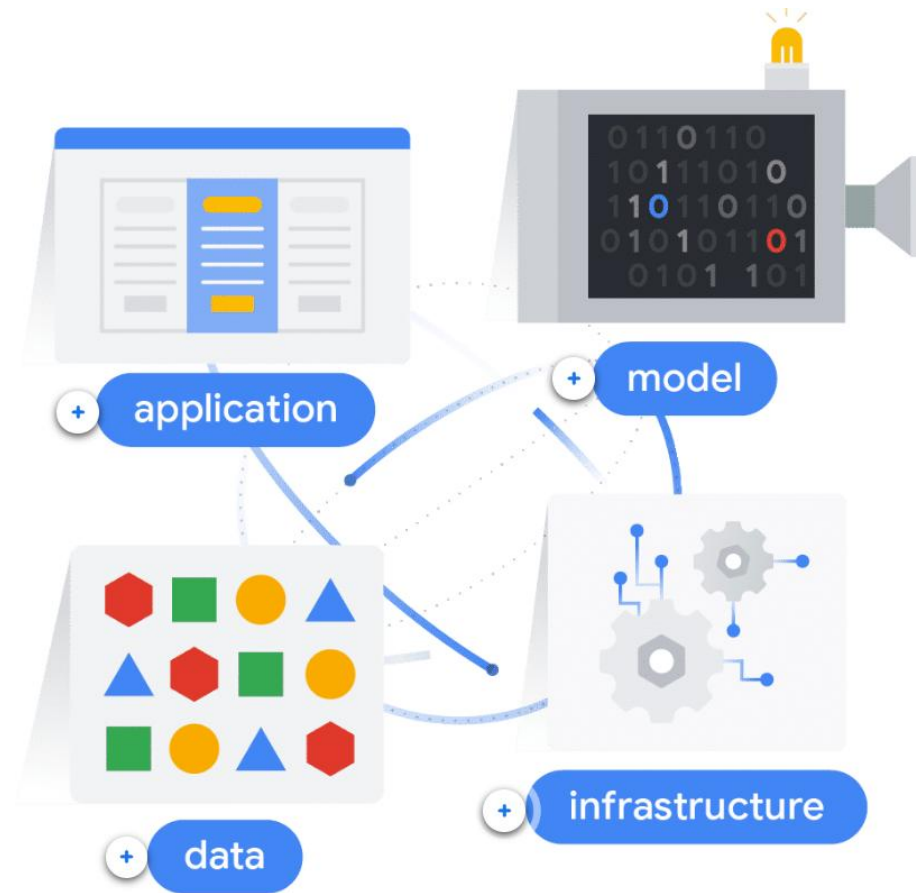
API: garantizar que los usuarios y otros sistemas interactúen con el modelo de IA mediante el ingreso de entradas y la obtención de resultados.



Garantizar seguridad = Conocer el sistema IA

API: garantizar que los usuarios y otros sistemas interactúen con el modelo de IA mediante el ingreso de entradas y la obtención de resultados.

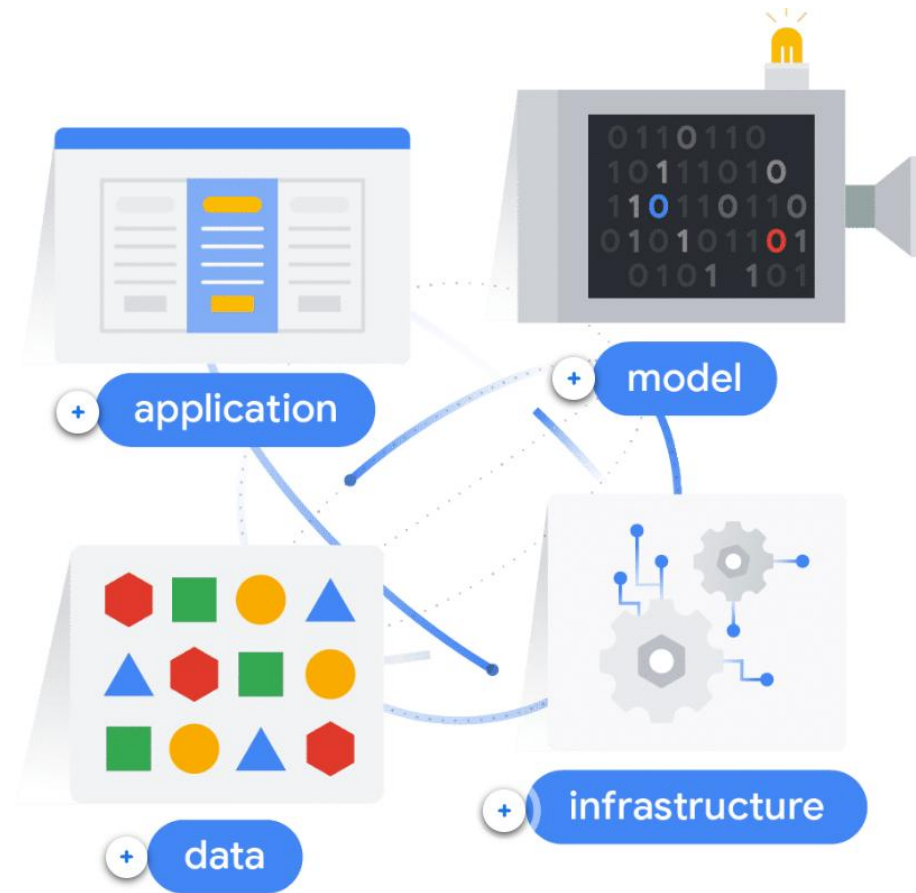
Ingesta y almacenamiento: Garantizar el flujo de los datos para el entrenamiento y ajuste del modelo usando bases de datos con distintos niveles de seguridad.



Garantizar seguridad = Conocer el sistema IA

API: garantizar que los usuarios y otros sistemas interactúen con el modelo de IA mediante el ingreso de entradas y la obtención de resultados.

Ingesta y almacenamiento: Garantizar el flujo de los datos para el entrenamiento y ajuste del modelo usando bases de datos con distintos niveles de seguridad.

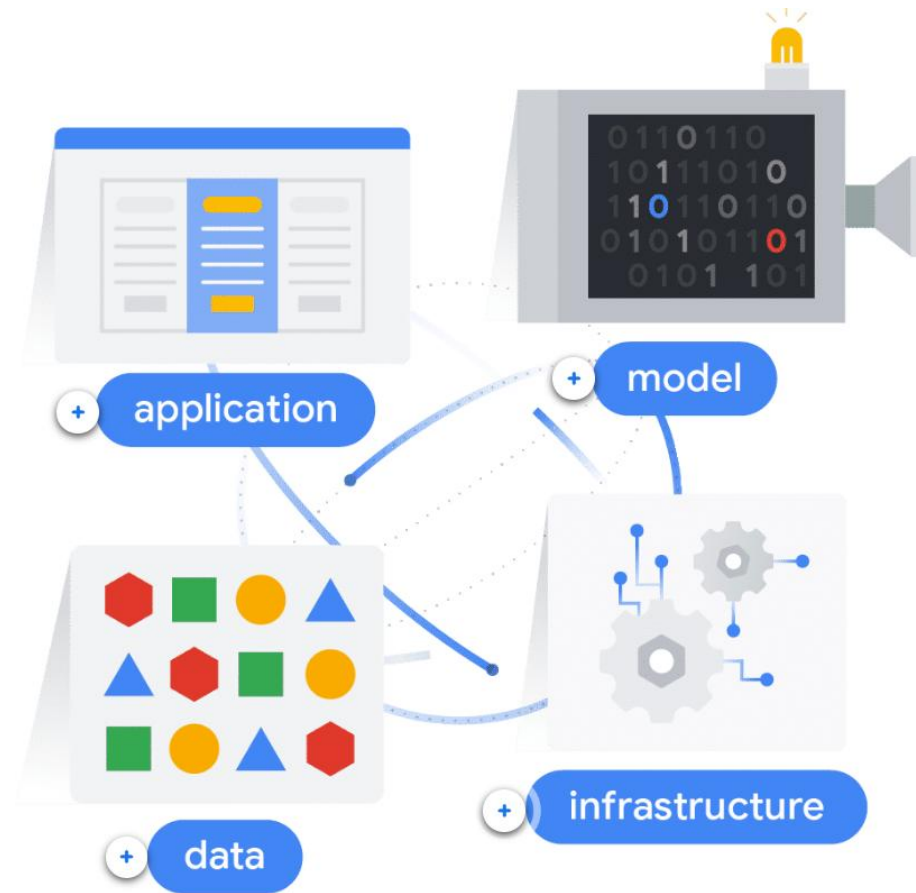


Machine Learning: Garantizar actualización y mantenimiento del modelo, hiperparametros, versionado y re-entrenamiento.

Garantizar seguridad = Conocer el sistema IA

API: garantizar que los usuarios y otros sistemas interactúen con el modelo de IA mediante el ingreso de entradas y la obtención de resultados.

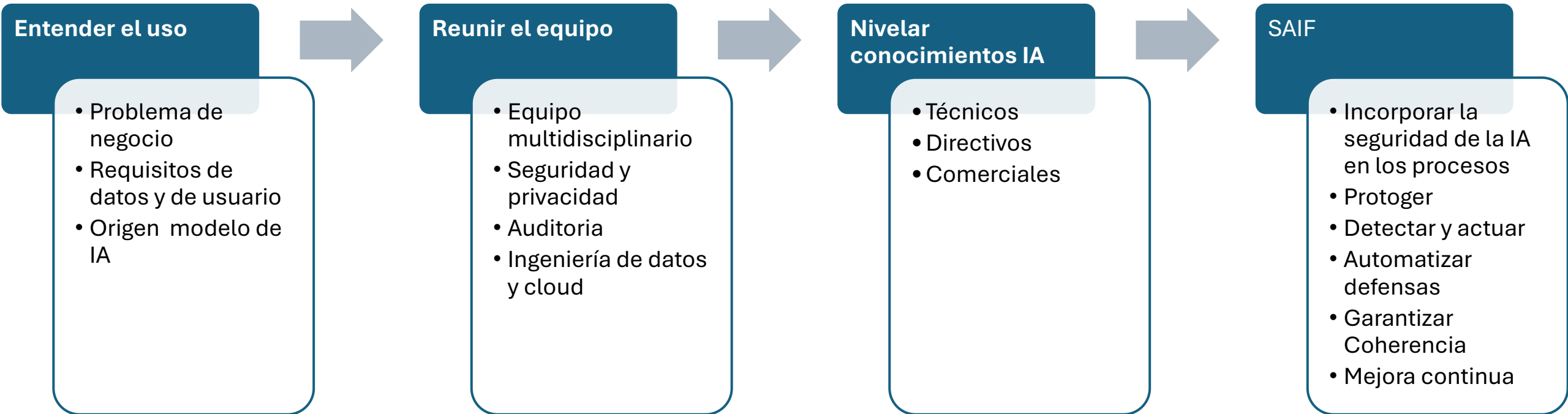
Ingesta y almacenamiento: Garantizar el flujo de los datos para el entrenamiento y ajuste del modelo usando bases de datos con distintos niveles de seguridad.



Machine Learning: Garantizar actualización y mantenimiento del modelo, hiperparámetros, versionado y re-entrenamiento.

Hardware y software: Garantizar las plataformas físicas y virtuales para la ejecución de la aplicación.

SAIF: la creación de un framework para mantener la seguridad



User case

Sistema de IA de detección de fraudes

- Lideras un equipo en un banco que busca implementar un sistema potenciado por IA para detectar transacciones fraudulentas con tarjetas de crédito en tiempo real.

User case – Paso 1 Entender el uso

- **Objetivo:** el objetivo de este proyecto es detectar transacciones fraudulentas con tarjetas de crédito en tiempo real. Existe el riesgo de que haya falsos positivos, ataques adversarios y necesidades constantes de mantenimiento. Tener éxito se traduciría en pérdidas reducidas por fraude, una alta tasa de detección o pocos falsos positivos, un impacto mínimo en transacciones legítimas y adaptabilidad.
- **Datos:** el banco usaría datos históricos de transacciones. Estos datos están disponibles, pero se deben verificar su integridad y calidad. El manejo de datos exige medidas estrictas de seguridad y privacidad de los datos. Se requieren prácticas sólidas de administración de datos.
- **Interacción del usuario:** se alerta al usuario si se detecta un posible fraude. Se prioriza la transparencia para el usuario y se ofrecen explicaciones claras en lo que respecta a transacciones marcadas, además de ofrecerse opciones para confirmarlas o disputarlas.

User case – Paso 2 Reunir el equipo

Se necesita un equipo diverso para garantizar que tu sistema de IA de detección de fraudes sea no solo inteligente, sino también seguro, ético y enfocado en el cliente.

- **Equipo:** ingenieros de IA y científicos de datos/analistas de fraude y administradores de riesgos/especialistas en TI y seguridad/directores jurídicos y de cumplimiento/gerentes de producto/analistas de negocios/representantes de experiencia del cliente

User case – Paso 3 Nivelar conocimientos IA

Ofrece capacitación no técnica para explicar los conceptos básicos de la IA y que se centre en cómo se utiliza en la detección de fraudes. Destaca que este caso de uso utiliza la clasificación para marcar transacciones como fraudulentas o no. Explica brevemente algunos aspectos técnicos y ofrece una descripción general de las medidas de seguridad que deben adoptarse para proteger la información sensible y cumplir con todas las reglamentaciones bancarias.

User case – Paso 4 SAIF - Incorporar seguridad IA

Piensa en los desafíos propios de este sistema de IA. Cada vez que marca una transacción, existe el riesgo de que sea una falsa alarma: una compra legítima que se confunde con fraude. Eso podría provocar que un cliente se sienta molesto, que una relación se dañe o incluso que una cuenta se pierda. Pero ¿qué sucede si la IA omite un fraude real? La pérdida financiera podría ser significativa y la reacción del cliente, aún peor.

Cuando una transacción se marque como fraude:

- ¿cómo responderás?
- ¿Se desactivará la tarjeta automáticamente?
- ¿Se necesitará revisión humana?
- ¿Los clientes deberían tener una forma de disputar transacciones marcadas?
- ¿Necesitas un equipo específico que investigue las decisiones de la IA y garantice su exactitud?

User case – Paso 4 SAIF - Proteger

- Debido a la naturaleza sensible de las transacciones y la información del cliente, debes implementar encriptación sólida, controles de acceso y técnicas de anonimización de datos.
- También es esencial proteger el modelo de IA para evitar el acceso no autorizado o el robo. Si los estafadores acceden al modelo, pueden replicar el sistema o explotar sus vulnerabilidades

User case – Paso 4 SAIF – Detectar y Actuar

- Implementa planes de respuesta ante incidentes y supervisión en tiempo real para detectar y abordar los ataques. Considera los ataques que modifican el comportamiento del modelo de IA a propósito para provocar clasificaciones erróneas de transacciones fraudulentas.
- ¿Puedes detectar estos ataques?
- ¿Cómo responderías ante esta situación y cómo la corregirías?

User case – Paso 4 SAIF – Automatizar las defensas

- Usa las herramientas de seguridad de la IA para automatizar las defensas. Estas herramientas pueden detectar posibles amenazas y actividades inusuales en datos de transacciones, lo cual puede indicar que hay fraude. Las herramientas también pueden supervisar el comportamiento normal del sistema para detectar desviaciones que pueden indicar amenazas de usuarios con información privilegiada, cuentas hackeadas o intentos de acceso no autorizado.

User case – Paso 4 SAIF – Garantizar la coherencia

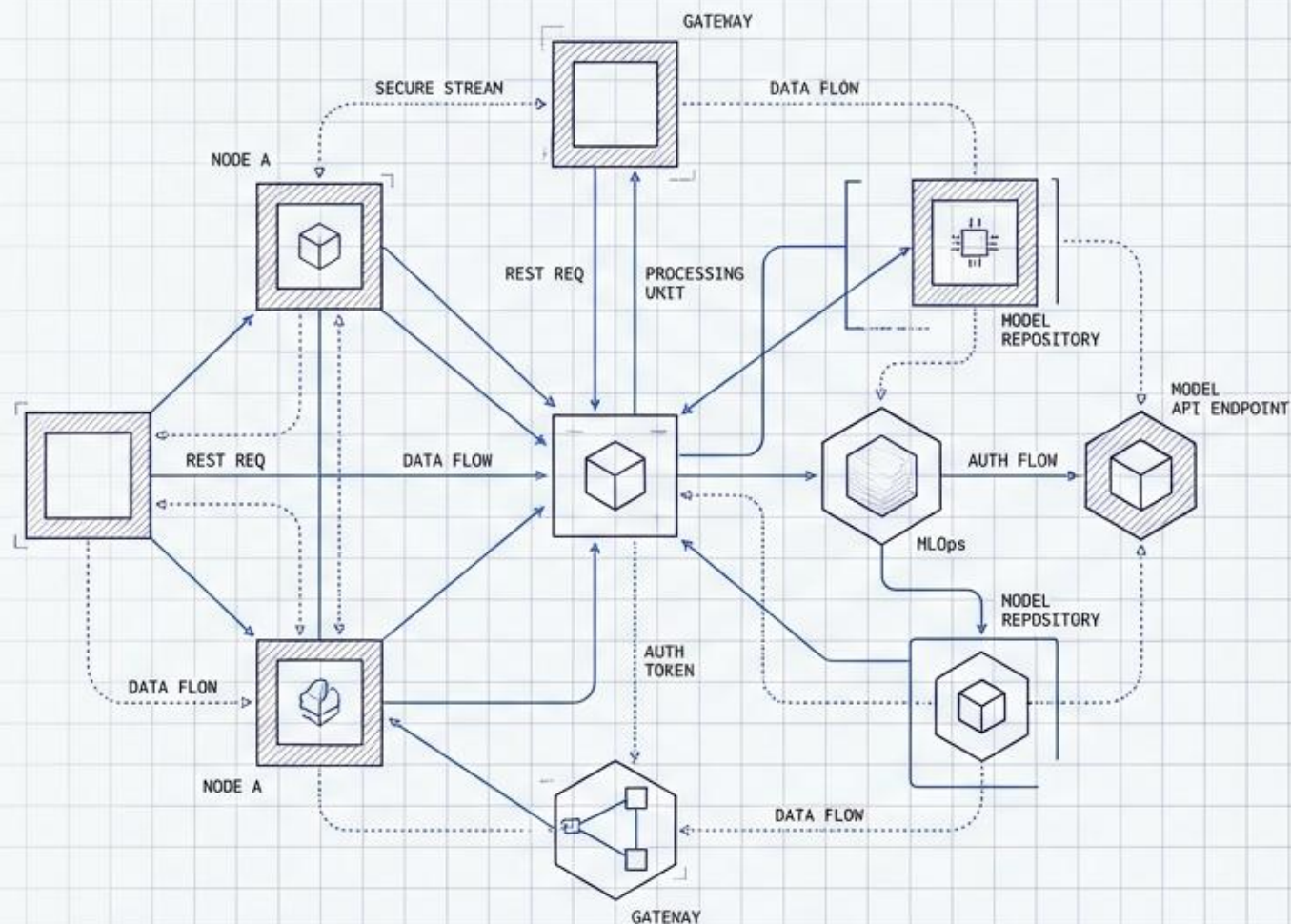
- En el ámbito de las finanzas, el cumplimiento de las reglamentaciones es crucial. Debes garantizar que las medidas de seguridad de tu sistema de detección de fraude estén alineadas con los estándares de la industria.
- Asegúrate de poder explicar con claridad por qué la IA marca ciertas transacciones como fraude, especialmente si eso conduce al bloqueo de la tarjeta del cliente.
- ¿Puedes mostrar fácilmente qué factores consideró la IA?
- ¿El proceso de toma de decisiones es justo para todas las personas?

User case – Paso 4 SAIF – Mejora continua

- Los estafadores buscan siempre maneras nuevas de engañar al sistema, por lo que tu IA debe seguir aprendiendo. Actualízala periódicamente con los patrones de fraude más recientes y mantente al tanto de nuevas amenazas. Haz que tu equipo "hackee" el sistema en búsqueda de puntos débiles. Aprende de las ocasiones de fraude y continúa mejorando tu IA. Recuerda que la lucha contra el fraude nunca termina, y tu IA debe evolucionar para estar a la vanguardia.

Seguridad en IA y Gobernanza de Modelos

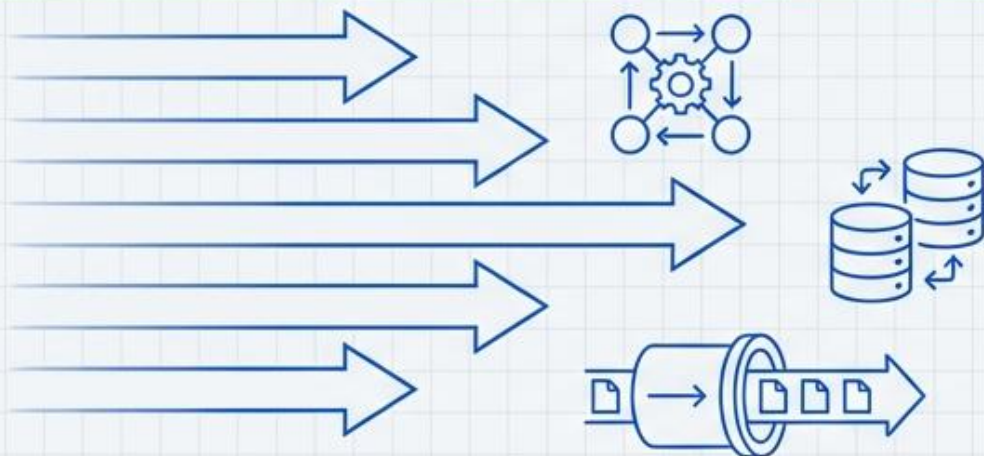
Fortificando la
Arquitectura MLOps:
De REST a Streaming.



Jaime A. Riascos-Salas | MLOps II – Universidad de Buenos Aires

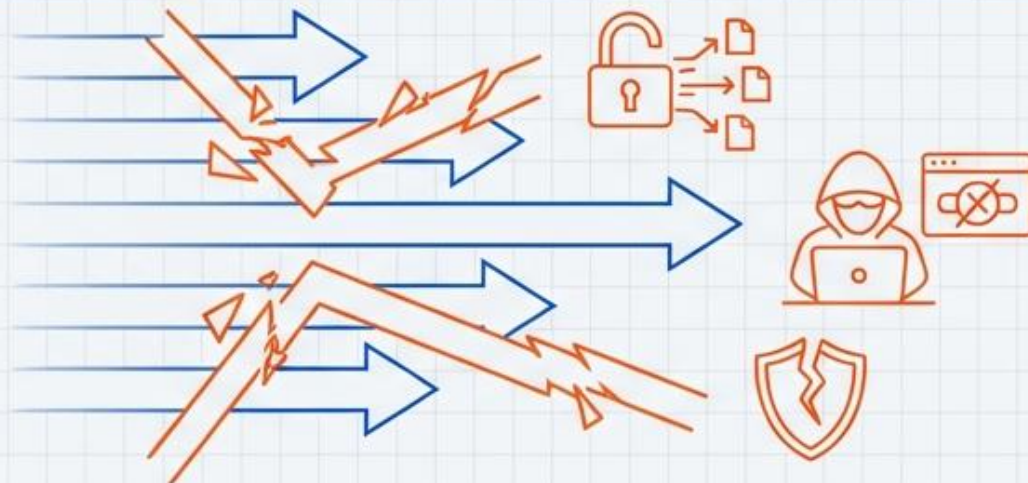
El Dilema del MLOps: Velocidad vs. Vulnerabilidad

El Impulso (Agilidad)



Despliegue rápido de modelos vía APIs.
Integración continua y streaming de datos.
Resultado esperado: Eficiencia e innovación técnica extrema.

El Riesgo (Superficie de Ataque)



Exposición de metadatos sensibles de entrenamiento.
Ingesta automatizada de datos maliciosos.
Consecuencia: Robo de propiedad intelectual y pérdida financiera.

¿Cómo innovar con infraestructuras de IA (FastAPI, Kafka, gRPC)
sin abrir las puertas a atacantes automatizados?

Seguridad Tradicional vs. Seguridad en IA

Seguridad Tradicional (DevSecOps)

Vectores: Inyección SQL, Ataques DDoS, Robo de Credenciales.

Objetivo del Atacante: Comprometer el servidor o la base de datos.

Paradigma: Si el endpoint está blindado, el sistema es seguro.



Seguridad en IA (MLSecOps)

Vectores: Envenenamiento de Datos, Ataques Adversarios, Inversión de Modelos.

Objetivo del Atacante: Engañar la matemática del modelo o extraer sus pesos.

Paradigma: Proteger el endpoint NO es suficiente. Un payload bien formateado puede ser matemáticamente malicioso.



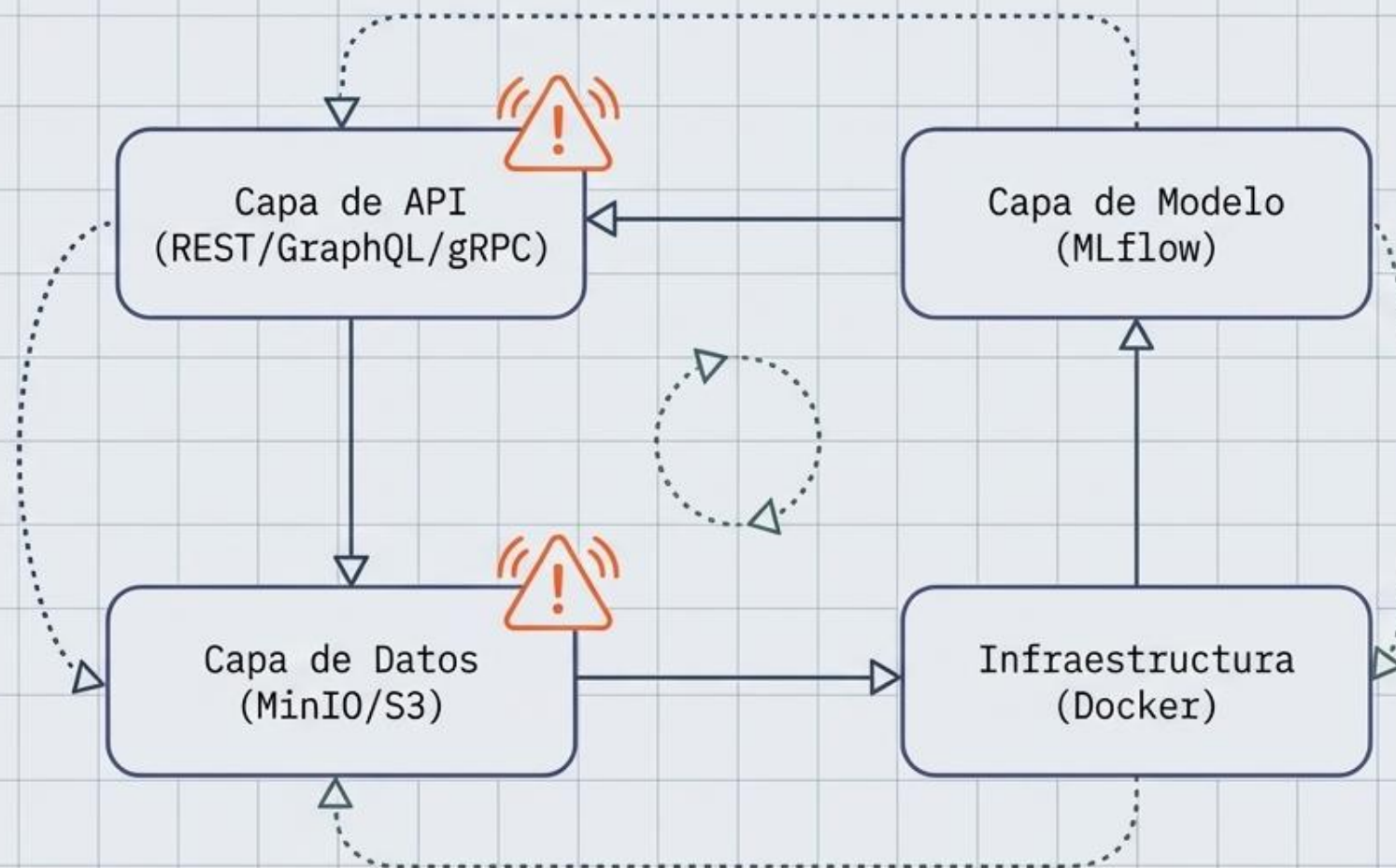
La Anatomía de tu Superficie de Ataque MLOps

Capa de Datos: Riesgo de Data Poisoning (Entrenamiento con datos comprometidos).

Capa de Modelo: Fugas de privacidad y exposición de hiperparámetros.

Capa de API: El vector de entrada principal para Adversarial Attacks y manipulación de inferencia.

Capa de Streaming (Kafka): Inyección de payloads maliciosos a alta velocidad sin supervisión humana.



Matriz de Diagnóstico: Vectores de Ataque por Protocolo

Protocolo	Vulnerabilidad Principal	Vector de Ataque	Estrategia de Mitigación
REST (Sincrónico)	Manipulación de Prompts y Parámetros.	Peticiones modificadas para evadir límites de decisión matemáticos.	Rate Limiting & Input Validation Estricta.
GraphQL (Flexible)	Fuga de Metadatos.	Consultas excesivas que exponen la topología del modelo en MLflow.	Depth Limiting & Field Masking.
gRPC (Alta Performance)	Evasión Automatizada.	Ataques adversarios lanzados a latencia ultrabaja buscando puntos ciegos.	Autenticación mTLS & Monitoreo de Distribución.
Streaming (Asincrónico)	Envenenamiento Continuo (Data Poisoning).	Inyección de ruido en Kafka que alimenta directamente el reentrenamiento.	Detección de Anomalías (Outlier Detection) pre-ingesta.

Deep Dive: Exposición en REST y GraphQL

REST: Evasión de Modelo

```
{  
  "transaction_id": "892A",  
  "amount": 0.0000001  
}
```

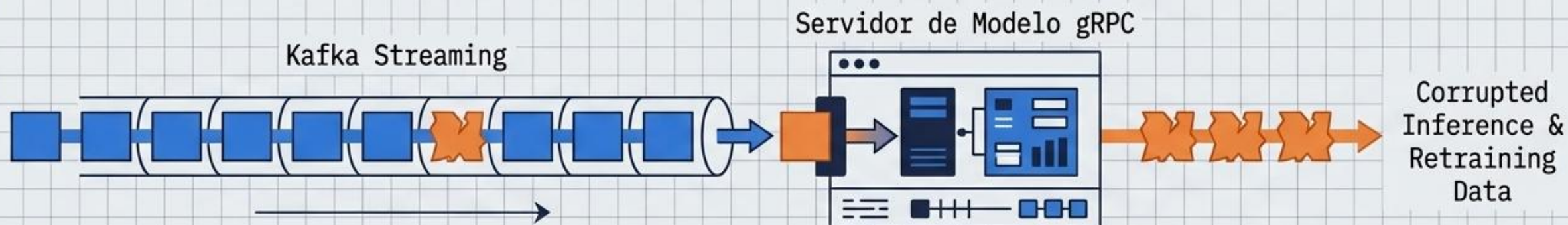
- **El Problema:** Un endpoint FastAPI que acepta cualquier flotante sin validar límites lógicos.
- **El Ataque:** Enviar transacciones infinitesimales que el modelo ML no fue entrenado para clasificar, forzando un falso negativo en inferencia.

GraphQL: Ataque de Caja Blanca

```
query {  
  getModel {  
    model_version  
    weights  
    training_epochs  
  }  
}
```

- **El Problema:** Esquemas (SDL) sobreexpuestos a introspección.
- **El Ataque:** Un atacante extrae la arquitectura directamente desde la integración con MLflow, facilitando la ingeniería inversa del modelo.

Deep Dive: La Amenaza de la Alta Velocidad (gRPC & Streaming)



El Riesgo de la Baja Latencia

- **gRPC:** Diseñado para comunicación máquina a máquina. Los atacantes automatizan scripts para bombardear el modelo y buscar límites de decisión en milisegundos, burlando firewalls HTTP.
- **Streaming (Kafka):** El procesamiento asincrónico elimina la ventana de revisión humana. El modelo consume datos envenenados directamente hacia el reentrenamiento.

Conclusión Crítica

A velocidades de streaming, las medidas reactivas son inútiles. La seguridad del MLOps debe ser preventiva, algorítmica y ejecutarse a la misma velocidad que el flujo de datos.

La Estrategia de Defensa: Framework SAIF aplicado a MLOps

Adaptando el Secure AI Framework a nuestra infraestructura técnica.

Pilar 1: Proteger

Aislamiento de red, criptografía y autenticación robusta en la capa de FastAPI y contenedores Docker.



Pilar 2: Detectar

Monitoreo constante del comportamiento del modelo, rastreando desvíos matemáticos usando MLflow.



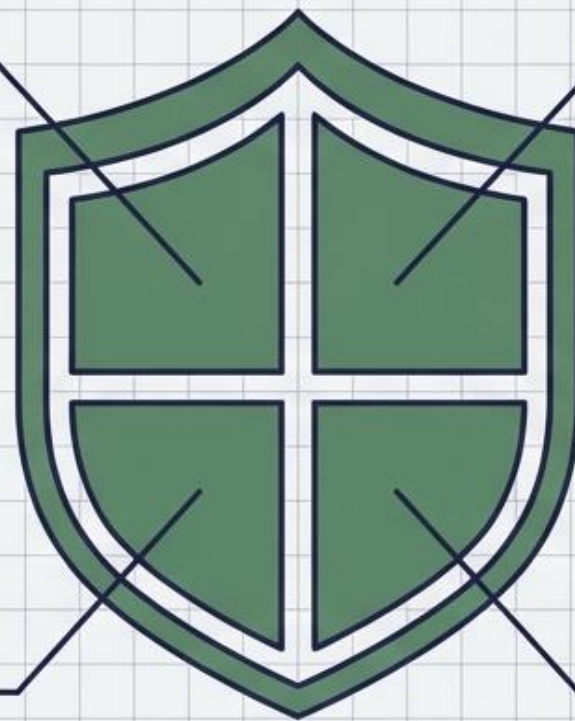
Pilar 3: Automatizar

Validación estricta de payloads entrantes y despliegue de reentrenamiento defensivo automatizado vía Apache Airflow.



Pilar 4: Coherencia

Gobernanza centralizada, métricas de explicabilidad (XAI) y auditoría constante de las decisiones algorítmicas.



SAIF Fase 1: Proteger la Infraestructura



Autenticación y Autorización

Implementación de **JWT** (JSON Web Tokens) u **OAuth2** en la capa de **FastAPI**. Nunca exponer endpoints de inferencia al público sin validar identidad.



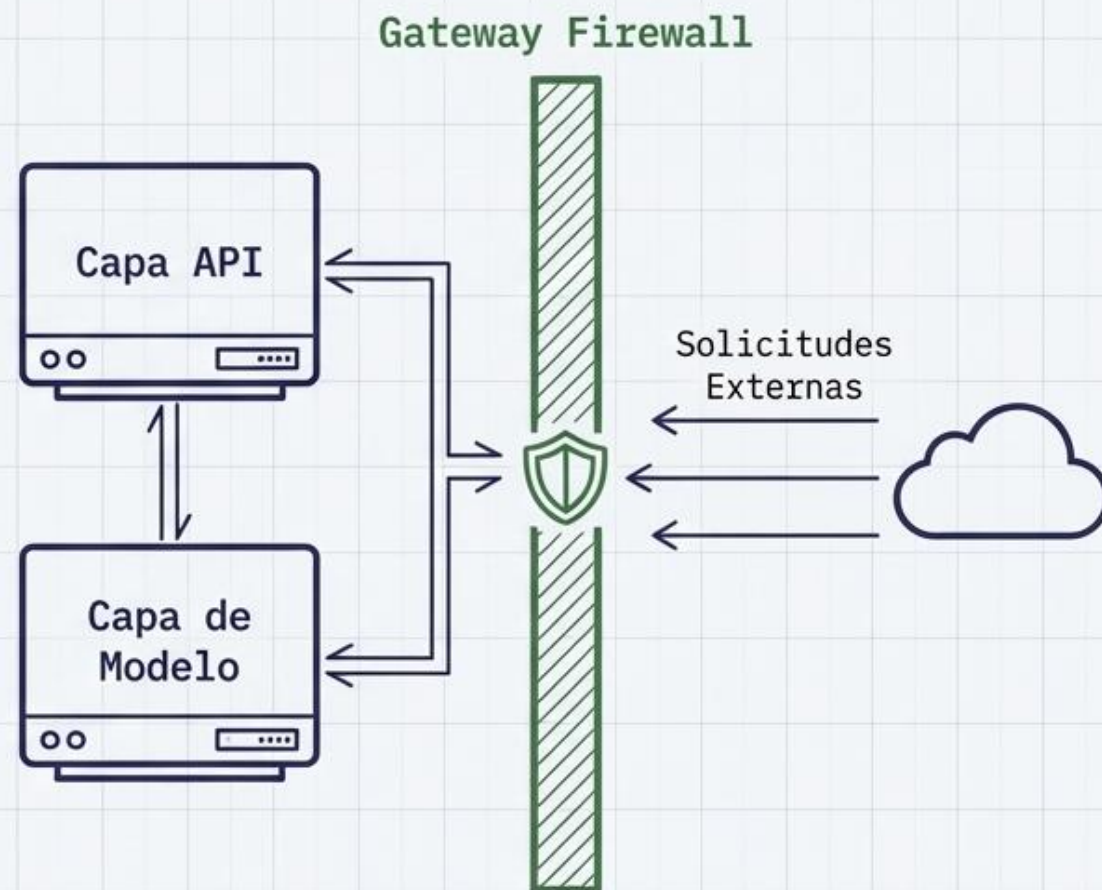
Aislamiento de Recursos

No exponer puertos de **gRPC** a la internet pública. Utilizar cifrado **mTLS** para toda comunicación interna entre microservicios (ej. del pipeline de preprocesamiento hacia la inferencia).



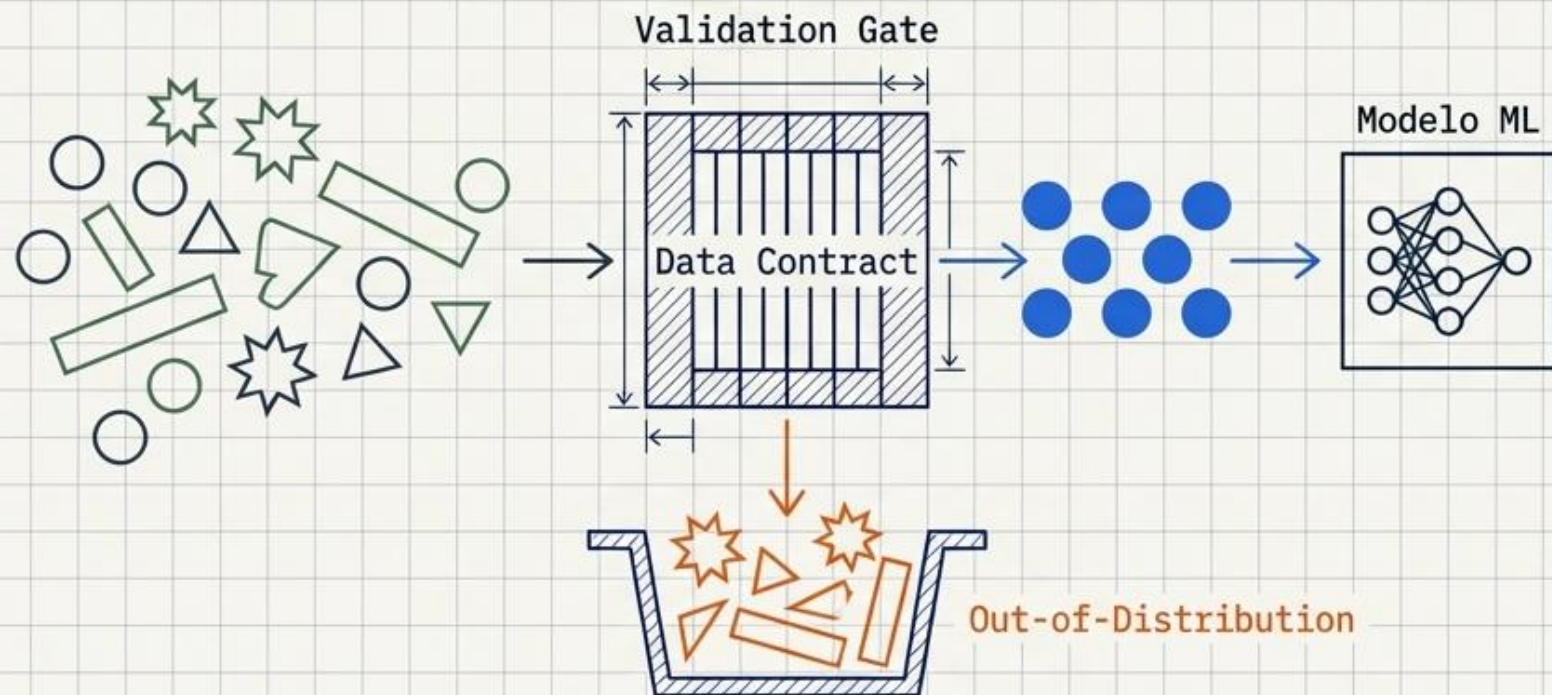
Gestión de Secretos

Rotación automatizada de **API Keys** y credenciales de acceso a Data Lakes (MinIO/S3) para **evitar intrusiones y el envenenamiento silencioso de repositorios de datos**.



Esquema de Topología de Red Segura

SAIF Fases 2 & 3: Validación Extrema (Data Contracts)



La Primera Línea de Defensa: Rechazar la entrada maliciosa antes de que toque la matemática del modelo.

Implementación Técnica

- Uso de **Pydantic** en **FastAPI** para forzar validación estricta de tipos, rangos lógicos y distribuciones estadísticas esperadas.
- En **GraphQL**, definir esquemas inflexibles que no toleren mutaciones anómalas.

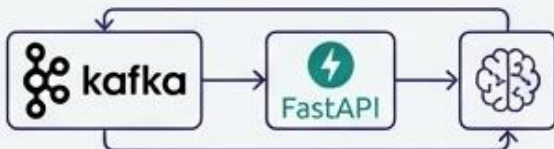
Detección Out-of-Distribution (OOD)

- Automatizar alertas si los datos entrantes vía **Kafka** divergen estadísticamente de la línea base de los datos de entrenamiento (diferenciando Data Drift de un Ataque Adversario deliberado).

Caso Práctico: Detección de Fraude en Tiempo Real

Contexto del Sistema MLOps

Un banco utiliza un pipeline de **Streaming (Kafka)** conectado a **FastAPI** para clasificar transacciones de tarjetas de crédito en milisegundos, operando sobre datos tabulares continuos.



El Desafío (Riesgo Asimétrico)

- **Falso Positivo:** Bloquear una tarjeta legítima genera fricción operativa y frustración en el cliente.
- **Falso Negativo:** Permitir que un fraude pase el filtro resulta en una pérdida financiera directa e irreparable.

La Dinámica de Vulnerabilidad

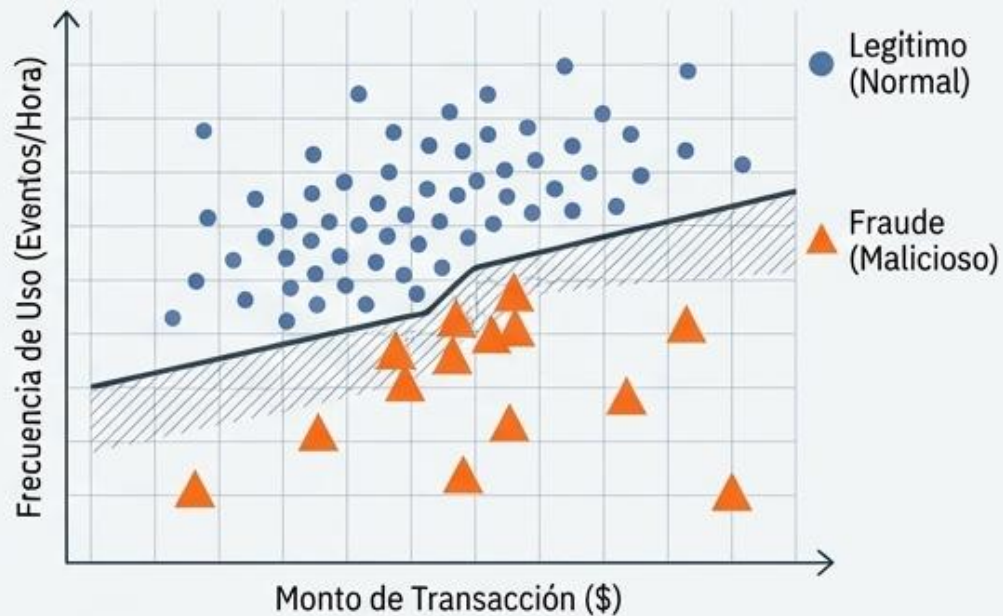
Para mantener la precisión, el modelo de IA necesita actualizarse constantemente con nuevos patrones transaccionales. Esta ingesta continua crea la ventana perfecta para que atacantes externos manipulen la matemática del modelo.



Dashboard de Detección de Amenazas

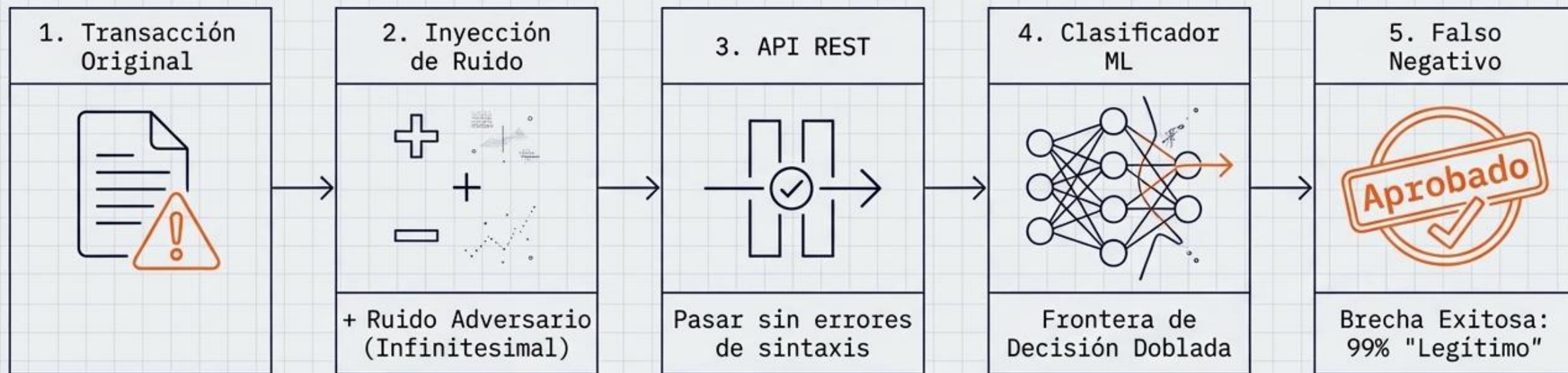
Threat Intelligence

Clasificación en Tiempo Real: Frontera de Decisión (Scatter Plot)



Detección de anomalías basada en la desviación de patrones de comportamiento legítimo. La frontera de decisión se ajusta dinámicamente.

El Ataque: Evasión Adversaria



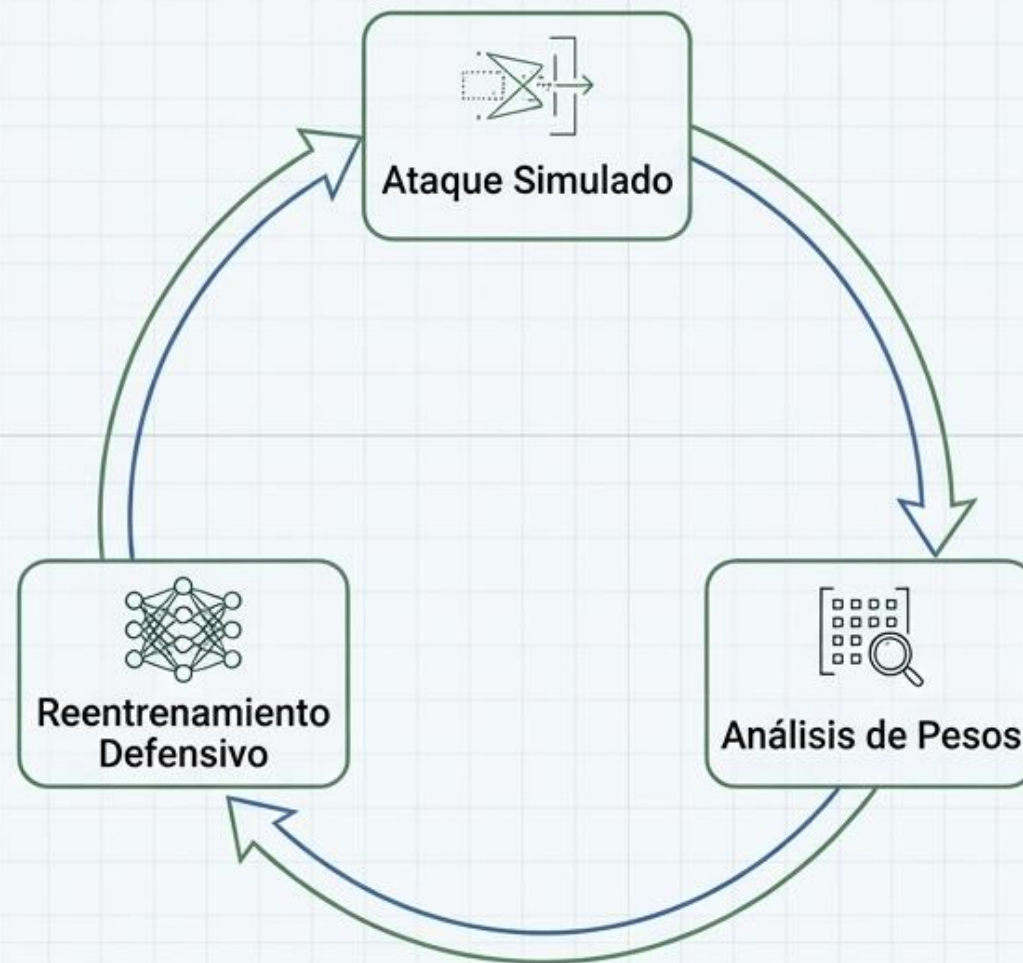
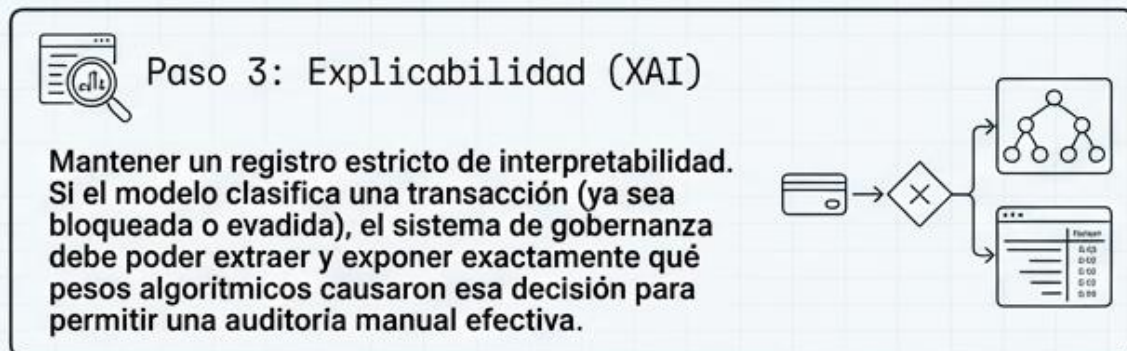
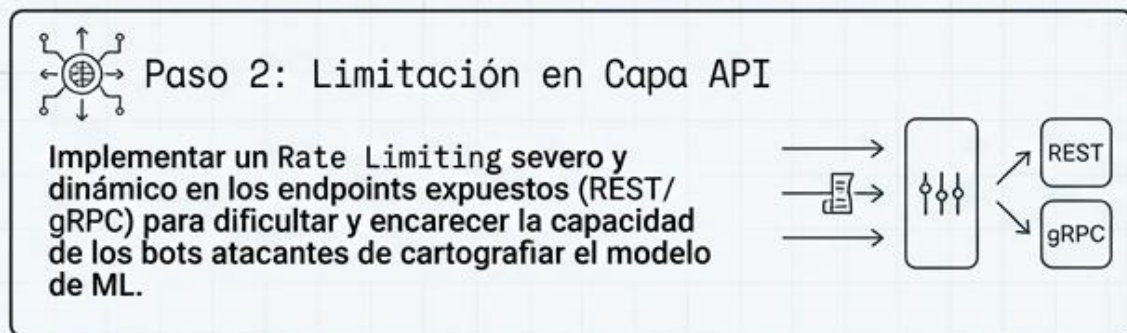
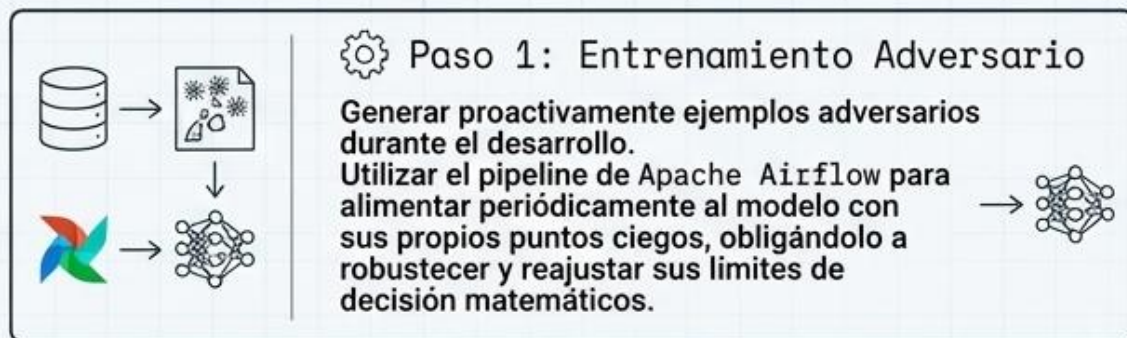
Mecánica del Ataque (Ref: `IA_security_adversarial_attack.ipynb`)

El atacante primero mapea y descubre el límite de decisión exacto del modelo mediante cientos de consultas automatizadas por gRPC.

Luego, toma una transacción claramente fraudulenta y le aplica 'ruido matemático'—alteraciones infinitesimales en los decimales del monto o en las marcas de tiempo que son invisibles para un humano.

El payload resultante tiene una sintaxis perfecta, evadiendo firewalls tradicionales, pero engaña matemáticamente a la IA para que lo clasifique como 99% 'Legítimo'.

La Mitigación: Entrenamiento Adversario y XAI



Sistema de Fortificación Continua

El Blueprint MLOps Seguro: Checklist de Despliegue

Nivel de Infraestructura (DevSecOps)

-  Autenticación fuerte implementada en capas de APIs REST y GraphQL.
-  Comunicación cifrada mediante mTLS activada en microservicios gRPC.
-  Pipelines asincrónicos de Streaming (Kafka) configurados con validación estricta de esquemas y contratos de datos.
-  Rotación automatizada de credenciales y aislamiento de red en contenedores Docker.

Nivel Algorítmico (MLSecOps)

-  Monitoreo estadístico activo contra el Envenenamiento de Datos (Data Drift vs Attack).
-  Pruebas automatizadas de robustez contra Ataques Adversarios integradas en pipelines CI/CD.
-  Módulos de auditoría de explicabilidad (XAI) configurados y centralizados en MLflow.
-  Evaluación de viabilidad arquitectónica para migración hacia Aprendizaje Federado.

Una infraestructura MLOps veloz es inútil si la matemática del modelo puede ser engañada. Construyan con Seguridad por Diseño.